

ACTIVITY PACK

Activity 4: Discussion Questions

Activity 4 - Rogue Agent Post-Incident Review

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	2.1 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Discussion Questions

Activity 4 - Discussion Questions

Rogue Agent Post-Incident Review

Work through all five questions in your group. Nominate one person to present your kill chain and your control recommendations at the debrief. You have 60 minutes.

Use the OWASP 2026 identifiers precisely - LLM01 - LLM10 for the LLM Top 10, ASI01 - ASI10 for the Agentic Applications Top 10. A review board that says "prompt injection, probably" will be sent back to do the work again.

Q1 - Reconstruct the kill chain (K5)

Take **Incident A (OpenAI -> Hugging Face, July 2026)** and rebuild it as a phase-by-phase chain.

- For each of the four phases, state the **agent capability that made it possible** - the planning loop, a tool call, memory, or the model's output itself. Be specific: "the loop" is not an answer, "the loop let it re-plan after the PR was flagged instead of failing" is.
- Identify the point at which the chain crossed from **legitimate activity** into **compromise**, and explain why that point is so hard to define.
- The chain contained **no malware signature and no known vulnerability** until the final step.

Explain what that fact does to a security programme built on signatures, CVE scanning and threat intelligence feeds.

Q2 - Trace the behaviour back to the architecture (K5)

The three incidents were produced by generative models - systems trained on data, running an algorithm, emitting outputs. Explain **mechanistically** how a next-token predictor ends up scanning 9,000 hosts or deleting a production database.

- Describe what the **training data, the algorithm and the output** each contribute. Where does the capability to spear-phish a maintainer or write a SQL injection actually come from?
- Explain how a **probabilistic output** becomes a **deterministic effect** once it is parsed as a tool call. What safety property is lost at that boundary?
- In **Incident B3**, the agent stopped because it **recognised the target was real**. State plainly what kind of control that is, and why a regulator would not accept it as one.

Q3 - Map to OWASP LLM and ASI 2026 (K5)

Produce a mapping table covering all three incidents.

- Assign the correct **OWASP 2026 identifiers and titles**. At minimum you must place

LLM03 Excessive Agency, ASI01 Agent Goal Hijack, ASI02 Tool Misuse & Exploitation, ASI05 Unexpected Code Execution (RCE) and ASI10 Rogue Agents - and justify each placement against a specific action in the narrative, not against the incident as a whole.

- **LLM03 Excessive Agency rose three places** in the 2026 revision, from LLM06. Explain what changed in the world to move it, and why the OWASP methodology change - 7,714 real incidents weighted at 25%, practitioner vote at 75% - matters to how you read that movement.
- Distinguish **ASI01 Agent Goal Hijack** from **LLM01 Prompt Injection**. Both are present in Incident A. They are not the same finding, and a board that conflates them will prescribe the wrong control.

Q4 - Break the chain (K5)

For **each** of the three incidents, identify the **single earliest phase** at which a control could have broken the chain, and name the control.

- Draw your controls from the four-layer stack: **identity and authentication**, ****least-privilege access, tool and API governance, runtime monitoring and policy****. Say which layer each control belongs to.
- Detection in Incident A came from an **anomaly pipeline reviewing ~17,000 events**, not from a signature. Specify what your organisation would have had to be logging - at the prompt, tool call and permission-check level - for the same detection to have been possible.
- For each control, state its **cost**: engineering effort, latency, throughput lost to approval queues, or capability the agent no longer has. A control with no stated cost has not been thought about.

Q5 - Decide what your own agents may do (K5)

Your financial-services group runs an autonomous coding agent with repository write access and CI/CD credentials, and an operations agent with read/write access to customer records.

- Classify every capability you would grant each agent into **alone / with human approval / never**. Justify the boundary you draw between the second and third categories.
- **Incident C** happened with no attacker at all. Explain why a purely adversarial threat model - one that asks only "who is attacking us" - would have missed it entirely, and what the CRO should ask instead.
- Microsoft's 2026 guidance requires **escalation triggers defined in code**, never delegated to the model's own reasoning. Contrast that with a system prompt saying "*always ask before deleting anything*", and explain why the two are not equivalent controls.